

**BINUS UNIVERSITY**  
Computer Science / Information Systems  
Semester Genap 2024/2025

**GSLC 2**  
**Software Networking & Administration**  
Laporan CI/CD Pipeline

**Core Calculation Engine**

Disusun oleh:

**Kelompok 6**

Slimper123 - M. Alif Rinaldi - 2802544690  
mikewijaya12 - Michael Wijaya - 2802416406  
Nikolas0077 - Nikolas Aesculapius - 2802473391  
Alexandro-S-O - Alexandro Julio Caesar Soplantila - 2802407843

Jakarta, Mei 2025

---

## DAFTAR ISI

|                                                      |          |
|------------------------------------------------------|----------|
| <b>BAB 1: DESKRIPSI APLIKASI.....</b>                | <b>3</b> |
| 1.1 Gambaran Umum .....                              | 3        |
| 1.2 Fitur Utama.....                                 | 3        |
| 1.3 Tech Stack .....                                 | 3        |
| 1.4 Struktur Repository .....                        | 4        |
| <b>BAB 2: CARA KERJA PIPELINE CI/CD .....</b>        | <b>4</b> |
| 2.1 Gambaran Pipeline .....                          | 4        |
| 2.2 Job 1 — Build & Unit Test.....                   | 4        |
| 2.3 Job 2 — SAST dengan Bandit.....                  | 5        |
| 2.4 Job 3 — SCA dengan Trivy .....                   | 5        |
| 2.5 Job 4 — Secret Scanning dengan TruffleHog .....  | 6        |
| 2.6 Job 5 — Security Summary Report.....             | 6        |
| 2.7 Diagram Alur Pipeline.....                       | 7        |
| <b>BAB 3: KORELASI PIPELINE DENGAN APLIKASI.....</b> | <b>7</b> |
| 3.1 Konteks Penggunaan Aplikasi.....                 | 7        |
| 3.2 Mengapa DevSecOps Diperlukan .....               | 7        |
| 3.3 Shift-Left Security .....                        | 8        |

## BAB 1: DESKRIPSI APLIKASI

### 1.1 Gambaran Umum

Aplikasi yang dikembangkan adalah Core Calculation Engine, sebuah web application kalkulator berbasis Python Flask yang menyediakan operasi aritmatika dan matematika melalui antarmuka web. Aplikasi ini dikontainerisasi menggunakan Docker sehingga dapat di-deploy secara konsisten di berbagai environment tanpa ketergantungan pada konfigurasi sistem host.

Aplikasi ini bersifat general-purpose dan dapat digunakan dalam berbagai konteks komputasi, mulai dari kalkulasi sederhana sehari-hari hingga kebutuhan teknis seperti perhitungan rekayasa dan sains. Antarmuka pengguna dirancang dengan gaya 8-bit pixel art yang interaktif dan responsif terhadap input keyboard maupun klik.

### 1.2 Fitur Utama

Aplikasi menyediakan 6 operasi matematika berikut:

- Penjumlahan ( $a + b$ )
- Pengurangan ( $a - b$ )
- Perkalian ( $a \times b$ )
- Pembagian ( $a \div b$ ) — dengan validasi pembagian nol
- Akar Kuadrat ( $\sqrt{a}$ ) — dengan validasi domain bilangan negatif
- Logaritma Natural ( $\ln a$ ) — dengan validasi domain bilangan  $\leq 0$

### 1.3 Tech Stack

- Backend: Python 3.10, Flask, Gunicorn
- Frontend: HTML5, CSS3, JavaScript (8-bit pixel art UI dengan font Press Start 2P)
- Containerization: Docker (base image python:3.10-slim)
- Testing: pytest dengan pytest-cov untuk code coverage report
- CI/CD: GitHub Actions (workflow otomatis pada push dan pull request ke main)

### 1.4 Struktur Repository

Struktur direktori utama repository adalah sebagai berikut:

- `src/app.py` — Core logic Flask application, fungsi kalkulasi, dan route HTTP
- `src/templates/index.html` — Tampilan UI kalkulator 8-bit pixel art
- `tests/test_app.py` — Unit test dan integration test (12 test case)

- Dockerfile — Konfigurasi Docker image berbasis python:3.10-slim
- requirements.txt — Daftar dependensi Python (Flask, Gunicorn, pytest, dll.)
- .github/workflows/CI-CD-pipeline.yml — Konfigurasi pipeline GitHub Actions

## BAB 2: CARA KERJA PIPELINE CI/CD

### 2.1 Gambaran Pipeline

Pipeline CI/CD dibangun menggunakan GitHub Actions dan dijalankan secara otomatis pada setiap push ke branch main maupun pull request ke branch main. Pipeline terdiri dari 5 job: 4 job pertama berjalan secara paralel, dan 1 job terakhir (Security Summary Report) menunggu semua job selesai sebelum dieksekusi.

### 2.2 Job 1 — Build & Unit Test

Tool: pytest + pytest-cov

Cara kerja:

1. Checkout source code dari repository
2. Setup Python 3.11
3. Install semua dependensi dari requirements.txt
4. Jalankan semua unit test dan integration test dengan pytest
5. Generate laporan code coverage dalam format XML
6. Upload coverage report sebagai artifact GitHub Actions

Relevansi terhadap Aplikasi: Kalkulator menangani operasi matematika yang harus menghasilkan nilai yang presisi dan benar. Pipeline menggunakan 12 test case yang mencakup happy path (input valid), edge case (input boundary seperti  $\sqrt{0}$  dan  $\ln(1)$ ), serta error case (divide by zero, sqrt negatif, ln negatif). Karena kalkulator bergantung pada kebenaran hasil komputasi, setiap perubahan kode wajib lolos semua test sebelum bisa masuk ke main branch.

### 2.3 Job 2 — SAST dengan Bandit (Static Application Security Testing)

Tool: Bandit (versi dengan dukungan pyproject.toml)

Cara kerja:

1. Checkout source code
2. Install Bandit
3. Scan seluruh source code di folder src/ secara statis (tanpa menjalankan kode)
4. Bandit mencari pola kode yang berpotensi menjadi kerentanan keamanan
5. Hasil scan di-output ke file bandit-report.txt dan di-upload sebagai artifact

Kerentanan yang dapat dideteksi Bandit:

- Hardcoded password atau secret key dalam source code
- Penggunaan fungsi berbahaya seperti `eval()`, `exec()`, atau subprocess dengan `shell=True`
- SQL injection patterns
- Penggunaan algoritma kriptografi yang lemah (MD5, SHA1)
- Input yang tidak di-sanitasi sebelum digunakan

Relevansi terhadap Aplikasi: Meskipun Core Calculation Engine adalah kalkulator sederhana, aplikasi ini menerima input dari pengguna melalui HTTP request. Tanpa sanitasi yang proper, input berbahaya dapat dieksploitasi. Bandit memastikan tidak ada pola kode berbahaya yang lolos ke production — misalnya penggunaan `eval()` untuk mengevaluasi ekspresi matematika yang rentan terhadap Remote Code Execution (RCE). Flask yang dikonfigurasi tanpa debug mode di production juga diverifikasi oleh Bandit.

## 2.4 Job 3 — SCA dengan Trivy (Software Composition Analysis)

Tool: Trivy oleh Aqua Security

Cara kerja:

1. Checkout source code
2. Trivy melakukan scan filesystem pada seluruh repository
3. Trivy memeriksa setiap dependensi di `requirements.txt` terhadap database CVE
4. Severity yang dipantau: CRITICAL, HIGH, MEDIUM
5. Hasil scan di-output ke `trivy-report.txt` dan di-upload sebagai artifact

Database CVE yang digunakan Trivy:

- NVD (National Vulnerability Database) — database kerentanan resmi NIST
- GitHub Security Advisories — advisory langsung dari maintainer library
- OSV (Open Source Vulnerabilities) — database terbuka untuk ekosistem open source

Relevansi terhadap Aplikasi: Aplikasi menggunakan dependensi pihak ketiga seperti Flask, Unicorn, dan Werkzeug. Setiap library dapat memiliki kerentanan yang ditemukan setelah versi tersebut dirilis. Trivy memastikan tim segera mengetahui jika ada CVE baru yang memengaruhi dependensi yang digunakan. Sebagai contoh, Werkzeug (dependency Flask) pernah memiliki vulnerability pada komponen debugger-nya (CVE-2024-34069) yang memungkinkan RCE. Trivy akan mendeteksi dan melaporkan hal ini kepada tim.

## 2.5 Job 4 — Secret Scanning dengan TruffleHog

## Tool: TruffleHog oleh Truffle Security

Cara kerja:

1. Checkout seluruh git history (fetch-depth: 0 — bukan hanya commit terakhir)
2. TruffleHog memindai setiap commit dari awal repository hingga HEAD
3. Menggunakan mode --only-verified untuk meminimalkan false positive
4. Deteksi secret berdasarkan entropy analysis dan pattern matching terhadap 700+ jenis credential

Jenis secret yang dapat dideteksi TruffleHog:

- API keys dari berbagai provider (AWS, GCP, Azure, GitHub, Stripe, dll.)
- Database credentials dan connection strings
- Private keys (RSA, SSH, PGP)
- OAuth tokens dan Bearer tokens
- Webhook URLs yang mengandung token autentikasi

Relevansi terhadap Aplikasi: Dalam proses development, developer kadang tidak sengaja melakukan commit secret ke repository — misalnya Flask SECRET\_KEY, database URL, atau API key eksternal. Bahkan jika commit tersebut dihapus, secret tetap ada di git history dan dapat diakses siapa saja yang meng-clone repository. TruffleHog memindai seluruh history untuk memastikan tidak ada credential yang pernah bocor. Untuk aplikasi Flask, SECRET\_KEY yang bocor dapat memungkinkan attacker memalsukan session cookie dan mengambil alih sesi pengguna.

## 2.6 Job 5 — Security Summary Report

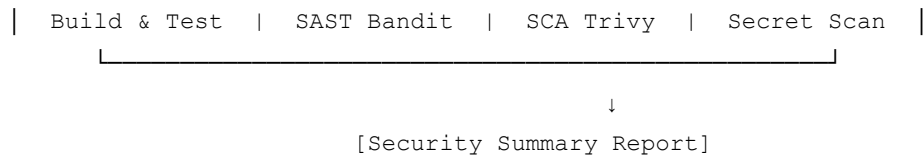
Job ini berjalan setelah semua job sebelumnya selesai, menggunakan konfigurasi needs: [...] dan if: always() sehingga tetap berjalan meskipun ada job yang gagal. Job ini menghasilkan ringkasan visual di GitHub Actions Step Summary yang menampilkan status masing-masing security check, daftar artifact yang dihasilkan, serta informasi build seperti branch, commit hash, dan timestamp.

## 2.7 Diagram Alur Pipeline

[Push / Pull Request ke branch main]

↓







## BAB 3: KORELASI PIPELINE DENGAN APLIKASI

### 3.1 Konteks Penggunaan Aplikasi

Core Calculation Engine, meskipun merupakan aplikasi kalkulator, merepresentasikan pola umum web application yang menerima input dari pengguna, memprosesnya di server, dan mengembalikan output. Pola arsitektur ini identik dengan berbagai aplikasi production seperti sistem keuangan, e-commerce, dan enterprise tools.

Operasi matematika seperti pembagian, akar kuadrat, dan logaritma natural yang ada pada aplikasi ini juga umum digunakan dalam konteks finansial (perhitungan bunga, amortisasi), sains (komputasi ilmiah), dan teknik (kalkulasi rekayasa). Oleh karena itu, kebenaran hasil perhitungan dan keamanan aplikasi menjadi aspek yang tidak dapat dikompromikan.

### 3.2 Mengapa DevSecOps Diperlukan

Pendekatan DevSecOps (Development + Security + Operations) diterapkan dalam pipeline ini karena beberapa alasan fundamental:

- 1. Aplikasi Menerima Input Eksternal:** Setiap field input dari pengguna adalah potential attack vector. SAST dengan Bandit memastikan kode tidak memiliki celah untuk code injection atau penggunaan fungsi berbahaya dalam memproses input tersebut.
- 2. Ketergantungan pada Library Pihak Ketiga:** Flask, Unicorn, Werkzeug, dan library lainnya dapat memiliki kerentanan yang ditemukan kapan saja. SCA dengan Trivy memberikan visibilitas real-time terhadap CVE pada setiap dependensi yang digunakan.
- 3. Risiko Kebocoran Credential:** Dalam proses development kolaboratif, secret key, database URL, atau API key bisa tidak sengaja masuk ke repository. Secret scanning dengan TruffleHog mencegah credential ini bocor ke publik melalui git history.
- 4. Kualitas dan Kebenaran Komputasi:** Unit test dengan coverage report memastikan setiap fungsi matematis berjalan dengan benar, termasuk edge case dan error handling untuk input tidak valid.

### 3.3 Shift-Left Security

Pipeline ini menerapkan prinsip Shift-Left Security — yaitu menempatkan pengecekan keamanan sedini mungkin dalam siklus development, bukan menunggu setelah deployment ke production. Dengan menjalankan Bandit, Trivy, dan TruffleHog pada setiap push dan

pull request ke main branch, kerentanan ditemukan dan dapat diperbaiki oleh developer di local environment mereka, bukan sesudah kode sudah berjalan di server production.

Biaya perbaikan kerentanan yang ditemukan di fase development jauh lebih rendah dibandingkan kerentanan yang baru ditemukan setelah deployment, baik dari segi waktu, tenaga, maupun risiko reputasi dan keamanan data pengguna. Pipeline DevSecOps ini memastikan bahwa setiap baris kode yang masuk ke branch main sudah melewati serangkaian gate keamanan yang komprehensif.